Microsoft Purview ISO 27001 Compliance Program

Implementation Solution Guide

Version 1.0.0 · 2026-07-07

Contents

Executive Summary — Microsoft Purview ISO 27001 Compliance Program 4
The problem . . . 4
The solution . . . 4
What it delivers . . . 4
Business outcomes . . . 4
Boundaries (so scope is clear) . . . 5
1. Solution Overview — Microsoft Purview ISO 27001 Compliance Program 5
What this solution is . . . 5
Why ISO 27001 maps onto Purview (and where it doesn't) . . . 6
How it works . . . 6
What you can control . . . 7
Limitations (be honest with buyers) . . . 7
Naming convention (used in every doc and script) . . . 8
The standard deployment model . . . 8
2. Requirements — Microsoft Purview ISO 27001 Compliance Program 9
2.1 Licensing sufficient for the ISO template and the supporting controls . . . 9
2.2 The ISMS scope, risk assessment, and Statement of Applicability (from the ISMS/risk function) 9
2.3 Compliance Manager roles with separation of duties . . . 10
2.4 Roles for the supporting technical controls . . . 10
2.5 Unified audit logging enabled (the evidence backbone) . . . 11
2.6 A classification intent and in-scope data (for labels, DLP, and retention) . . . 11
2.7 A pilot scope, simulation/test mode, and change control . . . 11
2.8 An evidence owner, register, and retention approach . . . 12
Global Requirements — Microsoft Purview Solutions 13
1. Microsoft 365 tenant with the required Purview/compliance licensing . . . 13
2. Purview roles (least-privilege) and portal access . . . 13
3. Security & Compliance PowerShell + Graph toolchain . . . 14
4. Data sources & scope in scope . . . 14
5. Compliance, records, privacy & legal stakeholders . . . 14
6. A pilot scope and change control . . . 14
3. Implementation Guide — Microsoft Purview ISO 27001 Compliance Program 15
Phase 0 — Connect and baseline (Assess) . . . 15
Phase 1 — Map the in-scope Annex A controls to Purview (Design) . . . 16
Phase 2 — Stand up the Compliance Manager assessment spine (Configure — guardrails) . . . 16

Phase 3 — Configure the supporting technical controls in SIMULATION/TEST (Configure — no user impact) . . . 17
Phase 4 — Validate the evidence and enforce in a pilot ring (Pilot → Validate) . . . 18
Phase 5 — Expand, report, and operate (Expand → Continual improvement) . . . 18
Order-of-operations summary . . . 19
5. Testing & Validation — Microsoft Purview ISO 27001 Compliance Program 19
Test A — Control mapping & coverage (nothing in-scope is unmapped) . . . 20
Test B — Evidence collection (each control is defensible) . . . 20
Test C — Technical control behaviour & simulate-first discipline . . . 21
Simulate-first & rollback validation . . . 22
Evidence to capture (for the deliverable record) . . . 22
6. Troubleshooting — Microsoft Purview ISO 27001 Compliance Program 23
Compliance Manager / assessment . . . 23
Control mapping . . . 23
Evidence collection . . . 24
Technical controls not behaving . . . 24
Audit / logging evidence . . . 24
Scripts / tooling . . . 25
7. Best Practices — Microsoft Purview ISO 27001 Compliance Program 26
Let the SoA drive the map — never the other way around . . . 26
Simulate/test before you enforce — always . . . 26
Evidence is the product — automate its collection . . . 26
Segregation of duties (A.5.3) — build it into roles . . . 27
Classification, DLP, and retention hygiene . . . 27
Insider Risk / Communication Compliance — privacy by design . . . 27
Operate as a continual-improvement program (Clause 10) . . . 27
Stay inside the boundary . . . 28
8. Deliverables Summary — Microsoft Purview ISO 27001 Compliance Program 28
Documentation . . . 28
PowerShell tools (5) — Security & Compliance PowerShell / Graph . . . 29
Definition of done . . . 30
Appendix A — PowerShell Scripts 31

Executive Summary — Microsoft Purview ISO 27001 Compliance Program

The problem

ISO/IEC 27001 certification depends on **controls that are implemented, operated, and evidenced**. A large share of the standard's technical controls — data classification, data leakage prevention, logging and monitoring, cryptography, information deletion, access restriction — already run inside the organization's Microsoft 365 tenant, but they are typically **unmapped to Annex A**, **unconfigured to policy**, and **unable to produce the evidence an auditor asks for**. The result is a compliance gap discovered late, a scramble for evidence, and data-security exposure in the meantime.

The solution

Stand up an **ISO 27001-aligned Microsoft Purview program**: take the **in-scope Annex A controls from the Statement of Applicability**, **map** each to the Purview capability that satisfies or evidences it, use **Compliance Manager's ISO/IEC 27001 assessment template** as the scoring-and-evidence spine, and **configure the supporting technical controls** — sensitivity labels, DLP, retention/disposition, unified audit, encryption. Every high-impact control is **built and proven in SIMULATION/TEST first** (zero user impact), validated against pass/fail gates, then enforced to a **pilot ring**, then expanded. The result: mapped controls, configured to policy, backed by **audit-ready evidence** with owner, date, and proof.

What it delivers

• A signed-off **Annex A** → **Purview control map** — the right capability for each in-scope control, with partial coverage and out-of-Purview controls called out honestly.

• The **Compliance Manager ISO assessment** stood up with an owned, dated **improvement-action / evidence plan **and least-privilege** role separation** (segregation of duties).

• The **supporting technical controls** — classification labels (A.5.12/5.13), data-leakage DLP (A.8.12), retention/disposition (A.8.10/5.33), logging/monitoring (A.8.15/8.16), cryptography (A.8.24) — each piloted in simulation/test, validated, and enforced.

• A complete **evidence register and coverage report** — every mapped control with owner, date, and test status, gaps flagged.

• **Five PowerShell tools** (posture discovery, control-config helper, evidence collector, coverage report, scope helper) — read-only or `-WhatIf` by default, no credentials in code.

Business outcomes

• **Audit-readiness** — the technical controls ISO 27001 expects are configured and continuously evidenced, so the audit is a review, not a fire drill.

• **Reduced data-security risk** — classification, data-leakage prevention, retention, and monitoring are live controls, not paper ones.

• **Minimal disruption** — simulate/test-first plus ring-based rollout means controls go live without breaking the business, and any control reverts to simulation instantly.

• **Self-guided at a fraction of consulting cost** — the same method a specialist would use, documented and tooled to run in-house.

Boundaries (so scope is clear)

This program delivers the **configured technical controls and the evidence** — it is **not** certification. The **ISMS scope, the risk assessment and treatment plan, the Statement of Applicability (which Annex A controls apply), the management-system clauses (4–10), retention schedules / records file plans, and the certification-body Stage 1 / Stage 2 audit** are **ISMS, risk, compliance, records, legal, and certification-body determinations**, captured alongside the delivered evidence. Purview covers the **technical subset** of Annex A — organizational, people, and physical controls are outside this program. Premium content and advanced controls are **licensing-gated (E5 / E5 Compliance — verify your tenant)**.

1. Solution Overview — Microsoft Purview ISO 27001 Compliance Program

What this solution is

ISO/IEC 27001 is the international standard for an **Information Security Management System (ISMS)**. Certification against it requires that a defined set of **controls** — the standard's clauses plus the **Annex A** control set — are selected, implemented, operated, and **evidenced**. A large portion of the controls an organization already runs Microsoft 365 for are **technical** — data classification, data leakage prevention, logging and monitoring, cryptography, information deletion, access restriction — and **Microsoft Purview** is where those controls are configured and where the **evidence** lives.

This solution is a repeatable, deploy-it-today way to stand up an **ISO 27001-aligned Purview program**: map the in-scope Annex A controls to the **Purview capabilities** that satisfy them, use **Compliance Manager's ISO/IEC 27001 assessment template** as the scoring and evidence spine, **configure** the supporting technical controls (sensitivity labels, DLP, retention/disposition, unified audit, encryption), **pilot every high-impact policy in simulation/test first**, **validate** the technical evidence against pass/fail gates, and **expand** to enforcement with a maintenance cadence. It uses only the **Microsoft Purview portal**, **Security & Compliance PowerShell** (`Connect-IPPSSession`), and **Microsoft Graph** — no third-party GRC tooling.

> ***Certification determinations are deferred.*** *This solution delivers the* ***technical control configuration and the evidence*** *that an ISO 27001 audit consumes. It does* ***not*** *make the certification determinations: the* ***scope of the ISMS****, the* ***risk assessment and risk treatment plan****, the* ***Statement of Applicability (SoA)*** *— which Annex A controls are applicable and why — the* ***management-system clauses*** *(Clause 4–10: context, leadership, planning, support, operation,*

*performance evaluation, improvement), and the **Stage 1 / Stage 2 certification-body audit** are **ISMS, compliance, risk, and certification-body determinations**. The solution provides the configured control and the proof; it does not decide applicability, adequacy, or certification.*

Why ISO 27001 maps onto Purview (and where it doesn't)

ISO/IEC 27001:2022 restructured Annex A into **93 controls** across **four themes** — **Organizational (37)**, **People (8)**, **Physical (14)**, and **Technological (34)**. This solution addresses the **subset that is technically satisfiable in Microsoft 365 / Purview** and provides the evidence for it. The **organizational, people, and physical** controls (policies, HR screening, awareness, physical security, supplier management) are **out of Purview's scope** — they are governance and operational matters this solution explicitly defers to the ISMS. Where a Purview control provides only *partial* evidence for an Annex A control, this solution says so; it never claims a control is "met" — that is the auditor's determination.

Representative Annex A (2022) technological/organizational controls this program provides evidence for (verify applicability against your SoA — the mapping is a starting point, not a determination):

Annex A (2022) control	Purview capability that provides evidence
A.5.12 Classification of information · **A.5.13 Labelling of information**	**Sensitivity labels** + label policy
A.8.12 Data leakage prevention	**DLP policies** (email, SharePoint, OneDrive, Teams, endpoint)
A.8.10 Information deletion · **A.5.33 Protection of records**	**Retention & disposition** (data lifecycle / records management)
A.8.15 Logging · **A.8.16 Monitoring activities**	**Unified audit log** (Audit Standard/Premium)
A.8.24 Use of cryptography · **A.5.14 Information transfer**	**Encryption / Message encryption**, label-applied encryption
A.8.11 Data masking	Label/DLP-driven protection where applicable (verify)
A.5.34 Privacy & protection of PII	PII SITs + DLP + retention (evidence only; determinations deferred)
A.5.15 / A.8.3 Access control / Information access restriction	Label-applied access + Conditional Access signals (evidence)
A.5.7 Threat intelligence · **A.6.8 reporting / A.8.16 monitoring**	Insider Risk / audit signals (HR-sensitive — privacy-by-design, deferred outcomes)

*The **authoritative control set and applicability are your SoA's**, produced by the ISMS/risk function. This table is the technical mapping the program configures and evidences.*

How it works

1. **Baseline (Assess).** Capture the current posture: whether **unified audit logging** is on, what

DLP / labels / retention already exist and in what mode, the **licensing** that gates the ISO template and advanced controls, and Compliance Manager's current **score** on the included Data Protection Baseline. Delivered read-only scripts produce this.

1. **Design the control map (Design).** With the ISMS/risk stakeholders, take the **in-scope Annex A

controls from the SoA** and map each to the Purview capability that satisfies it — the `ISO27001 Control Map – AnnexA-to-Purview` register. Applicability is the SoA's determination.

1. **Stand up the assessment spine (Configure).** In **Compliance Manager**, create the **ISO/IEC 27001

assessment **from its** premium template **(licensing-gated — verify entitlement), and build the** improvement-action / evidence plan** (`ISO27001 Action Plan – Evidence`): each action owned, dated, status-tracked, with evidence attached.

1. **Configure the supporting technical controls (Configure — pilot in simulation/test).** Build the

sensitivity-label scheme (A.5.12/5.13), **DLP policies** for data leakage (A.8.12), and **retention/disposition** for records/deletion (A.8.10/5.33) — **each piloted in simulation/test/disabled mode first**, then validated, then enforced. Confirm **unified audit** (A.8.15/8.16) and **cryptography/message encryption** (A.8.24) evidence.

1. **Validate the evidence (Pilot → Validate).** Confirm the **technical state** behind each mapped

control matches what the assessment claims, collect it into the `ISO27001 Evidence – Register`, and set test status/date — piloting any high-impact change in simulation/test first.

1. **Report and expand (Validate → Expand).** Roll up control coverage, evidence, and the score posture

(`ISO27001 Control Map` + evidence register); then move piloted policies to enforcement, add remaining in-scope controls, and stand up the **maintenance/continual-improvement cadence** (re-test, re-evidence, review owners, watch template/standard updates) that ISO's Clause 10 expects.

What you can control

- Which **Annex A controls** (from your SoA) the program configures and evidences in Purview.
- The **control-to-capability mapping** and the **evidence register** — owners, dates, status, proof.
- The **sensitivity-label scheme, DLP policies, and retention/disposition** that back the technical

controls — and, per the house model, whether each is in **simulation/test** or **enforced**.

- The **pilot scope** validated first (a pilot ring / a single assessment) before tenant-wide expansion.
- The **Compliance Manager role separation** (administrators / assessors / contributors / readers) that

makes the access record auditable.

Limitations (be honest with buyers)

- **This is not certification.** The program produces **configured controls and audit-ready evidence**;

it does not perform the **risk assessment**, write the **SoA/risk-treatment plan**, satisfy the **management-system clauses (4–10)**, or conduct the **certification-body Stage 1/2 audit**. Those are ISMS/risk/certification-body determinations — deferred.

- **Purview covers a subset of Annex A.** Organizational, people, and physical controls are largely

outside Purview and outside this solution; where Purview evidence is only **partial**, the program says so rather than claiming the control is met.

- **Premium content and advanced controls are licensing-gated.** The **ISO/IEC 27001 Compliance Manager

template **is a** premium template **(typically** Microsoft 365 E5 / E5 Compliance **or the Compliance Manager Premium Assessment Add-On), and advanced DLP/auto-labeling/Audit Premium are** E5 / E5 Compliance**. Some capabilities are** preview **and portal paths** evolve **— the program** verifies licensing/tenant**, never assumes.

- **Compliance Manager is portal-driven.** It has **no broad public PowerShell/Graph API** to create

assessments or set action status programmatically; the delivered scripts assess **readiness, roles, and the technical evidence** behind controls — they do not replace the portal.

- **Insider Risk / Communication Compliance are HR/privacy-sensitive.** Where used for A.5.7/A.6.8/A.8.16

evidence, apply **privacy-by-design, pseudonymization where applicable, and strict role separation** — case outcomes are **HR/legal** determinations, deferred.

- **No secrets in automation.** The scripts use interactive modern-auth sign-in; they never embed

credentials.

Naming convention (used in every doc and script)

Every artifact this solution creates or tracks is named `ISO27001 <Purpose> – <Scope> – <Stage>` and reused verbatim across the docs, scripts, and the Purview portal. The standard set:

Artifact	Name
ISO 27001 assessment (pilot)	`ISO27001 Assessment – Baseline – Pilot`
ISO 27001 assessment (production)	`ISO27001 Assessment – Annex A – Production`
Annex A → Purview control map	`ISO27001 Control Map – AnnexA-to-Purview`
Improvement-action / evidence plan	`ISO27001 Action Plan – Evidence`
Sensitivity-label scheme (A.5.12/5.13)	`ISO27001 Label – Classification – Pilot`
DLP policy — data leakage (A.8.12)	`ISO27001 DLP – Data Leakage – Simulation`
Retention / disposition (A.8.10/5.33)	`ISO27001 Retention – Records – Simulation`
Audit / logging evidence (A.8.15/8.16)	`ISO27001 Audit – Logging – Evidence`
Evidence register	`ISO27001 Evidence – Register`
Pilot user ring	`ISO27001 Pilot Ring – Stage1`
Role-separation evidence snapshot	`ISO27001 Roles – Separation Evidence`

The standard deployment model

__Assess__ the posture and licensing → __Design__ the Annex A → Purview control map from the SoA → __Configure__ the assessment spine and the supporting technical controls __in simulation/test__ → __Pilot__ (simulate/test → validate → enforce to a ring) → __Validate__ the evidence behind each mapped control against pass/fail gates → __Expand__ to enforcement, the full in-scope control set, and the continual-improvement cadence. Every high-impact change is piloted in simulation/test first, with a documented rollback. __Certification, applicability, and adequacy determinations are deferred to the ISMS/risk/compliance/certification-body functions at every step.__

2. Requirements — Microsoft Purview ISO 27001 Compliance Program

These are the **solution-specific** prerequisites for standing up an ISO 27001-aligned Purview program. They build on — and do not repeat — the six shared prerequisites in `global-requirements-purview.md` (tenant + compliance licensing, least-privilege Purview roles, S&C PowerShell + Graph toolchain, in-scope data sources, compliance/records/privacy/legal stakeholders, and a pilot scope + change control). Verify each item below before starting the Implementation Guide.

For every requirement: **Description** (what it is), **Why required**, **How to verify**, **How to implement if missing**.

2.1 Licensing sufficient for the ISO template and the supporting controls

• **Description:** The **ISO/IEC 27001 assessment template** in Compliance Manager is a **premium template**, and the technical controls that back Annex A (advanced/endpoint DLP, automatic labeling, Audit** Premium**, insider risk) are advanced capabilities — typically** Microsoft 365 E5 **or the** E5 Compliance **add-on, or the** Compliance Manager Premium Assessment Add-On** for additional premium assessments. Extends GR-#1.

• **Why required:** Without the entitlement, the **ISO template will not be available** to create the assessment, and advanced controls (endpoint DLP, auto-labeling, Audit Premium) that provide key evidence will not function. The **number** of premium assessments available depends on licensing/seat count.

• **How to verify:** In the **Microsoft 365 admin center** confirm the subscription/add-ons; in **Purview** → **Compliance Manager** → **Assessment templates** confirm the **ISO/IEC 27001** template is listed and selectable. **Flag "verify your licensing/tenant"** — availability evolves.

• **How to implement if missing:** Acquire/assign E5 / E5 Compliance (or the premium-assessment add-on) before creating the ISO assessment; scope the initial program to controls your plan covers.

2.2 The ISMS scope, risk assessment, and Statement of Applicability (from the ISMS/risk function)

• **Description:** The **defined ISMS scope**, the **risk assessment / risk-treatment plan**, and the

Statement of Applicability (SoA) that lists **which Annex A controls are applicable** and why — produced by the organization's ISMS/risk/compliance function, **not** by this solution.

• **Why required:** The program configures and evidences the **in-scope, applicable** controls. Without the SoA there is no authoritative list of which Annex A controls to map — and applicability is a **determination**, not a technical default.

• **How to verify:** Confirm a current, approved **SoA** and risk-treatment plan exist and name the applicable Annex A controls and their owners.

• **How to implement if missing:** Engage the ISMS/risk function to produce the SoA and risk treatment **before** the control-mapping phase. This is deferred to them; the program does not author it.

2.3 Compliance Manager roles with separation of duties

• **Description:** The **Compliance Manager role groups** assigned least-privilege — **Compliance Manager Administrators **(program owners),** Compliance Manager Assessors **(create assessments, edit test status),** Compliance Manager Contributors **(edit improvement actions),** Compliance Manager Readers **(auditors/oversight, read-only). Global/Compliance Administrator only where genuinely required. Extends GR-#2.** Verify exact role/role-group names in your tenant — Purview role naming evolves.**

• **Why required:** ISO 27001 values **segregation of duties** (A.5.3); Compliance Manager enforces fine-grained role groups, and separating administrators from contributors from read-only auditors is itself an auditable access control.

• **How to verify: Purview** → **Settings** → **Roles & scopes** → **Permissions** (or Microsoft Purview roles) — confirm membership of each Compliance Manager role group.

• **How to implement if missing:** Assign the least-privilege role groups under change control; separate program administrators, action contributors, and read-only auditors.

2.4 Roles for the supporting technical controls

• **Description:** The least-privilege Purview roles to configure the **supporting** controls the program evidences: **Information Protection** (sensitivity labels), **DLP Compliance Management / Compliance Data Administrator** (DLP), **Records Management / Retention Management** (retention/disposition), and **Audit** roles (unified audit / Audit Premium). Extends GR-#2.

• **Why required:** Each technical control is configured in its own Purview area under its own role; without the matching role the control cannot be built or its evidence collected.

• **How to verify:** Confirm the account(s) that will run the Implementation Guide hold the roles for labels, DLP, retention, and audit.

• **How to implement if missing:** Assign the least-privilege role groups per control area; separate authors from reviewers where possible.

2.5 Unified audit logging enabled (the evidence backbone)

• **Description: Unified audit logging** turned on for the tenant (Audit Standard; **Audit Premium**

where longer retention / higher-value events are needed) — the source of the logging and monitoring evidence (A.8.15 Logging, A.8.16 Monitoring activities) and the trail behind DLP/label/retention activity.

• **Why required:** A large share of ISO 27001 technical evidence — who did what, when, to which data —

comes from the audit log. Labels, DLP, and retention activity, and the delivered evidence/report scripts, all depend on it.

• **How to verify:** Confirm audit logging is on (e.g. `Get-AdminAuditLogConfig |

Select UnifiedAuditLogIngestionEnabled`, or the Purview **Audit** page). The Discovery script reports this.

• **How to implement if missing:** Enable unified audit logging and confirm ingestion **before** relying

on any logging/monitoring evidence — audit data only accrues from the time it is enabled.

2.6 A classification intent and in-scope data (for labels, DLP, and retention)

• **Description:** A documented view of the **information categories** in scope for classification

(A.5.12/5.13), the **data-leakage channels** DLP must cover (A.8.12), and the **records/retention requirements** (A.8.10 Information deletion, A.5.33 Protection of records) — mapped to the SITs, labels, and retention settings that implement them. Extends GR-#4.

• **Why required:** The label scheme, DLP policies, and retention/disposition all key off the

classification intent and the in-scope data; without it, the technical controls are guesswork.

• **How to verify:** Confirm the classification scheme, the DLP-covered locations, and the

records/retention requirements with the data owners and records function.

• **How to implement if missing:** Define the classification intent and in-scope data with stakeholders;

the retention *schedule* and records *file plan* are records/legal determinations — deferred — you configure the settings they specify.

2.7 A pilot scope, simulation/test mode, and change control

• **Description:** A named **pilot ring** (`ISO27001 Pilot Ring – Stage1`) and the agreement that each

high-impact control — **DLP, sensitivity labels, retention/disposition** — is built in **simulation/test/disabled mode first**, with a **change-control window** to move to enforcement. Extends GR-#6.

• **Why required:** Labels, DLP, and retention are high-impact; enforcing without a simulation/test

baseline and a limited ring is how these controls disrupt the business. The house model mandates **simulate/test first**, then a ring, then expand.

• **How to verify:** Confirm the pilot ring membership, that simulation/test mode is selected on each new

policy, and the approval path to enforce.

• **How to implement if missing:** Define the ring and agree change control before enabling any enforcement.

2.8 An evidence owner, register, and retention approach

• **Description:** A named owner for the `ISO27001 Evidence – Register` and a decision on **where evidence lives and how long it is kept** — improvement-action evidence in Compliance Manager, plus the exported technical evidence (audit extracts, policy/label/retention configuration snapshots, test results) the delivered scripts produce.

• **Why required:** ISO 27001 audits consume **evidence with owner, date, and proof**. A control without a retained evidence trail is not defensible; someone must own collecting, storing, and refreshing it.

• **How to verify:** Confirm the evidence owner, the storage location, and the evidence-retention approach.

• **How to implement if missing:** Assign the owner and agree the storage/retention before the validation phase generates evidence.

Requirements summary

#	Requirement	Gate
GR 1–6	Category prerequisites (`global-requirements-purview.md`)	Tenant/licensing, roles, toolchain, scope, stakeholders, pilot + change control
2.1	Licensing for ISO template + advanced controls (E5 / E5 Compliance; verify)	ISO template + advanced controls available
2.2	ISMS scope, risk assessment, **SoA** (from ISMS/risk)	Applicable Annex A controls defined (determination deferred)
2.3	Compliance Manager roles with separation	Auditable, least-privilege program access
2.4	Roles for labels / DLP / retention / audit	Supporting controls configurable
2.5	Unified audit logging enabled	Logging/monitoring evidence backbone present
2.6	Classification intent + in-scope data	Labels/DLP/retention key off correct scope
2.7	Pilot ring + simulation/test + change control	Simulate/test-first enforced
2.8	Evidence owner + register + retention	Evidence is owned, stored, defensible

> ***Deferred to the ISMS / risk / compliance / records / legal / certification-body functions:*** *the ISMS scope, the risk assessment and treatment plan, the* ***Statement of Applicability*** *(which Annex A controls apply), the management-system clauses (4–10), retention* ***schedules*** */ records* ***file plans****, and the* ***certification determination*** *itself. This solution provides the technical control configuration and the evidence, not those determinations.*

Global Requirements — Microsoft Purview Solutions

These requirements apply to **every** solution in the **Purview** category (implementing and managing Microsoft Purview, sensitivity & retention labels, DLP, data lifecycle & records, insider risk, communication compliance, audit, data security posture management, and data governance). Verify each before starting a solution's implementation steps.

> ***Vendor boundary (applies to every Purview solution).*** *The* ***Microsoft Purview portal*** *(purview.microsoft.com), the* ***Microsoft 365 admin center****,* ***Security & Compliance PowerShell*** *(`Connect-IPPSSession`), and* ***Microsoft Graph*** *are authored at exact, current click-by-click / cmdlet detail from Microsoft's public documentation. Microsoft Purview features are heavily* ***licensing-/plan-dependent*** *(many require* ***Microsoft 365 E5*** *or the* ***E5 Compliance*** *add-on; some are in preview) and the portal is* ***actively evolving*** *— capability availability and portal paths are* ***cited or flagged "verify your licensing/tenant"****, never asserted or invented.* ***Regulatory, records-retention, and legal determinations*** *(retention schedules, records file plans, legal holds, insider-risk case actions, regulatory applicability) are* ***deferred to the organization's compliance, records, privacy, and legal functions*** *— the solutions provide the technical configuration method and evidence, not the determination. Automation is* ***PowerShell*** *(Security & Compliance PowerShell / Graph) — never with hardcoded credentials or secrets.*

1. Microsoft 365 tenant with the required Purview/compliance licensing

• **Description:** A Microsoft 365 tenant with the **compliance licensing** the capability requires (E3 for baseline; **E5 / E5 Compliance** for advanced DLP, auto-labeling, insider risk, communication compliance, Audit Premium, DSPM, etc.).

• **Why required:** Most Purview capabilities are plan-gated; the feature won't be available without the right plan.

• **How to verify:** In the M365 admin center confirm the subscription/add-ons; check the feature is visible in the Purview portal.

• **How to implement if missing:** Assign/purchase the required licensing before starting.

2. Purview roles (least-privilege) and portal access

• **Description:** Access with the least-privilege **Purview / compliance role** the solution names (e.g. Compliance Administrator, Compliance Data Administrator, Information Protection, Records Management, Insider Risk, eDiscovery, Audit roles), with Global Administrator only where required.

• **Why required:** Purview uses fine-grained role groups; configuration requires the matching role.

- **How to verify:** Purview portal → **Roles & scopes / Permissions** — confirm the role membership.
- **How to implement if missing:** Assign the least-privilege role group under change control.

3. Security & Compliance PowerShell + Graph toolchain

- **Description:** A workstation with **Security & Compliance PowerShell** (`Connect-IPPSSession` via the

ExchangeOnlineManagement module) and **Microsoft Graph PowerShell**, modern-auth / MFA-capable admin.

- **Why required:** Configuration, automation, and the provided scripts run through these.
- **How to verify:** `Connect-IPPSSession` and `Connect-MgGraph` succeed with the admin account.
- **How to implement if missing:** Install the modules and confirm modern-auth sign-in before running steps.

4. Data sources & scope in scope

- **Description:** The **workloads and data sources** in scope (Exchange, SharePoint, OneDrive, Teams,

endpoints/devices, and — for data governance — the broader data estate) and a **data-classification / sensitivity** intent to drive labels, DLP, and retention.

- **Why required:** Purview policies key off the in-scope workloads and the classification scheme.
- **How to verify:** Confirm the in-scope workloads and the classification/sensitivity approach with

stakeholders.

- **How to implement if missing:** Define the scope and classification intent before authoring policies.

5. Compliance, records, privacy & legal stakeholders

- **Description:** Engagement with the **compliance, records-management, privacy, security, and legal**

stakeholders whose policies the configuration must satisfy (retention schedules, records file plans, regulatory obligations, insider-risk and communication-compliance policy, legal hold).

- **Why required:** Purview configuration must align to enterprise policy and legal/records requirements,

not technical defaults; several capabilities have HR/legal sensitivity.

- **How to verify:** Confirm the applicable policies, the records schedule, and named approvers.
- **How to implement if missing:** Identify the owners and capture the requirements before configuring.

6. A pilot scope and change control

- **Description:** A **pilot scope** (users/sites/policies in simulation or a limited ring) to validate

on before tenant-wide enforcement, and a **change-control** process — most Purview policies support a **simulation / test / disabled** mode that MUST be used before enforcement.

• **Why required:** Every solution follows an **Assess → Design → Configure → Pilot (simulate) → Validate

→ Expand (enforce)** model; DLP, labels, retention, and insider-risk changes are high-impact.

• **How to verify:** Confirm a named pilot scope, that simulation/test mode is available, and a change window/approval path.

• **How to implement if missing:** Define the pilot and agree change control before enforcing anything.

*The deployment model across every Purview solution is the same: **Assess** → **Design** → **Configure** → **Pilot (simulate/test)** → **Validate** → **Expand (enforce)**, with explicit pass/fail gates and a documented rollback. Automation is delivered as **PowerShell** (Security & Compliance PowerShell / Graph) — never with hardcoded credentials or secrets. Regulatory/records/legal determinations are deferred to the relevant governance functions.*

3. Implementation Guide — Microsoft Purview ISO 27001 Compliance Program

This is the exact, ordered procedure to stand up an ISO 27001-aligned Purview program: map the in-scope Annex A controls to Purview capabilities, stand up the Compliance Manager assessment spine, configure the supporting technical controls **in simulation/test first**, validate the evidence, then enforce and expand. Portal paths and cmdlets are from Microsoft's public documentation; **licensing-/plan-dependent features and evolving portal paths are flagged "verify your licensing/tenant"** and are never asserted for your tenant. Do the phases in order. Each phase names its artifacts (from the Overview naming table), states a **pass/fail gate**, and gives a **rollback**.

> ***Automation.*** *The five delivered PowerShell tools run through **Security & Compliance PowerShell** (`Connect-IPPSSession`) and **Microsoft Graph**. They are **read-only or** `-WhatIf` **by default**; writes require an explicit* `-Commit` *switch and never leave a policy in enforce. No credentials are stored in code. **Compliance Manager itself has no broad public API** — assessments, improvement actions, and evidence upload are done in the **portal**; the scripts assess readiness, roles, and technical evidence.*
>
> ***Determinations deferred.*** *The **SoA** (which Annex A controls apply), the **risk treatment**, the **retention schedule / records file plan**, the **management-system clauses (4–10)**, and the **certification** itself are ISMS / risk / records / legal / certification-body decisions. This guide configures and proves the technical controls and produces the evidence; capture those determinations from the responsible functions before each phase that depends on them.*

Phase 0 — Connect and baseline (Assess)

1. **Connect the toolchain** (GR-#3). On the admin workstation:

```
Install-Module ExchangeOnlineManagement -Scope CurrentUser -Force   # provides Connect-IPPSSession
Connect-IPPSSession -UserPrincipalName admin@contoso.com            # Security & Compliance PowerShell
Connect-MgGraph -Scopes 'Organization.Read.All','Policy.Read.All','InformationProtectionPolicy.Read' -N
```

1. **Run the posture assessment** (delivered script #1, read-only):

```
.\ISO27001-Discovery.ps1 -CsvPath .\ISO27001-Posture.csv
```

It reports whether **unified audit logging** is on, existing **DLP / label / retention** objects and their **mode** (simulation/test vs enforce vs disabled), and **licensing** signals that gate the ISO template and advanced controls.

1. **Confirm licensing** (Req 2.1) — E5 / E5 Compliance (or the premium-assessment add-on) so the

ISO/IEC 27001 template is available in Compliance Manager and advanced DLP/labeling/Audit Premium function. **Verify in the admin center and in Compliance Manager → Assessment templates.**

1. **Capture the Compliance Manager baseline.** In **Purview → Compliance Manager**, record the current

Compliance Score on the included **Data Protection Baseline** as the starting posture.

Pass/fail gate: you have a written baseline (audit state, existing controls + modes, licensing confirmed, ISO template visible, current score). **Rollback:** none (read-only).

Phase 1 — Map the in-scope Annex A controls to Purview (Design)

Do **not** decide applicability — take it from the **SoA** (Req 2.2). Map only the **in-scope, applicable** Annex A controls that Purview can satisfy or evidence.

1. **Build the control map** `ISO27001 Control Map – AnnexA-to-Purview`. For each in-scope Annex A control

from the SoA, record: the **control ID/title**, the **Purview capability** that satisfies/evidences it, whether the evidence is **full or partial**, the **owner**, and the **evidence type**. Use the Overview mapping table as the starting point (A.5.12/5.13 → labels; A.8.12 → DLP; A.8.10/5.33 → retention; A.8.15/8.16 → audit; A.8.24/5.14 → encryption). **Flag controls Purview does not cover** (organizational/people/physical) as out of scope for this program.

1. **Confirm the classification intent, DLP channels, and records requirements** (Req 2.6) that the

technical controls will implement — the label scheme, the DLP-covered locations, and the retention/disposition settings. *The retention **schedule** and records **file plan** are records/legal determinations — you configure what they specify.*

Pass/fail gate: every in-scope, applicable Annex A control maps to a named Purview capability (or is explicitly marked out-of-Purview), with an owner and evidence type; the map is signed off by the ISMS function. **Rollback:** none (design artifact).

Phase 2 — Stand up the Compliance Manager assessment spine (Configure — guardrails)

1. **Assign Compliance Manager roles with separation** (Req 2.3). In **Purview → Settings → Roles &

scopes**, populate** Compliance Manager Administrators / Assessors / Contributors / Readers **least-privilege; snapshot the membership as** `ISO27001 Roles – Separation Evidence`**.** Verify the exact role-group names in your tenant.**

1. **Create the ISO assessment.** In **Compliance Manager → Assessments → Add assessment**, select the

ISO/IEC 27001 premium template (verify it is available — Req 2.1) and create `ISO27001 Assessment – Baseline – Pilot` (start with one assessment to pilot the workflow), then, once proven, `ISO27001 Assessment – Annex A – Production`.

1. **Build the improvement-action / evidence plan** `ISO27001 Action Plan – Evidence`. For each

improvement action tied to an in-scope control, assign an **owner**, a **target date**, an **implementation status**, and a **test status**, and note the **evidence** it will carry. Where a Compliance Manager action maps to a technical control you will configure in Phases 3–4, link them.

1. **Enable automatic testing where available.** Compliance Manager can auto-test **eligible** actions

from Microsoft 365 signals — enable it so technical actions self-update. Availability is plan/action-dependent — **verify**.

Pass/fail gate: the ISO assessment exists, roles are separated and snapshotted, and every in-scope control has an owned, dated improvement action with a defined evidence type. **Rollback:** remove the pilot assessment / action-plan entries (no tenant configuration changed by Compliance Manager).

Phase 3 — Configure the supporting technical controls in SIMULATION/TEST (Configure — no user impact)

Build each high-impact control in **simulation/test/disabled** mode first. These provide the evidence for the mapped Annex A controls.

1. **Sensitivity-label scheme (A.5.12 Classification, A.5.13 Labelling) — `ISO27001 Label –

Classification – Pilot`. **Portal:** Information Protection → Labels **— create the label taxonomy the classification scheme requires (e.g. *Public / Internal / Confidential / Highly Confidential*), with protection (encryption/marking) where A.8.24 requires. Publish via a** label policy **scoped to the** pilot ring **only,** without** making labeling mandatory initially. Verify auto-labeling availability against your plan.

1. **DLP policy for data leakage (A.8.12) —** `ISO27001 DLP – Data Leakage – Simulation`**.**

Portal: **Data loss prevention** → **Policies** → **Create policy** → locations (Exchange, SharePoint, OneDrive, Teams, and **Devices** if endpoint DLP is licensed/onboarded) → conditions on the relevant SITs/labels → **Policy mode: Run the policy in simulation mode**. Do **not** enforce yet.

1. **Retention & disposition (A.8.10 Information deletion, A.5.33 Protection of records) — `ISO27001

Retention – Records – Simulation`. **Portal:** Data lifecycle management **(retention policies) and** Records management **(retention labels / disposition) — configure the retention/deletion the records requirements specify, applied to a** pilot scope **first, with** disposition review** where records must be reviewed before deletion. *The retention schedule/file plan is a records/legal determination — configure what it specifies.*

1. **Confirm cryptography and information-transfer evidence (A.8.24, A.5.14).** Confirm

encryption/message encryption state (e.g. label-applied encryption, Purview Message Encryption for email) — this is largely a configuration/evidence confirmation, not a high-impact toggle.

1. **Confirm logging/monitoring evidence (A.8.15/8.16).** Confirm **unified audit** (Req 2.5) is on and

capturing label/DLP/retention activity — the `ISO27001 Audit – Logging – Evidence` source.

1. **Verify the configuration** with the config helper (delivered script #2, `-WhatIf` by default):

```
.\ISO27001-Config.ps1 -Control DLP -PolicyName 'ISO27001 DLP – Data Leakage – Simulation' -WhatIf
```

Run with `-Commit` only to apply an intended change; the script never leaves a policy in enforce.

Pass/fail gate: labels published to the pilot ring, DLP in **simulation**, retention applied to the pilot scope, and audit/encryption evidence confirmed — script #1/#2 report each policy in a simulation/test/disabled mode, correctly scoped. **Rollback:** unpublish the label policy, delete the simulation DLP policy, and remove the pilot retention policy — simulation/test scopes have no broad user impact, so removal is clean.

Phase 4 — Validate the evidence and enforce in a pilot ring (Pilot → Validate)

1. **Collect the technical evidence** (delivered script #3, read-only) into the evidence register:

```
.\ISO27001-ControlEvidence.ps1 -ControlMap .\ISO27001-ControlMap.csv -CsvPath .\ISO27001-Evidence.csv
```

It confirms, per mapped control, the technical state (audit enabled; DLP policies + mode; labels + label policy; retention policies; and, via Graph, licensing/Conditional-Access signals) and produces `ISO27001 Evidence – Register`.

1. **Validate against the pass/fail gates** (see Testing) — each mapped control's technical state matches

what the assessment claims; attach the evidence to the Compliance Manager improvement action and set **test status/date**.

1. **Enforce the piloted controls for the ring.** Move `ISO27001 DLP – Data Leakage – Simulation` to

enforce (policy tips + allow-override) for `ISO27001 Pilot Ring – Stage1`; make the label policy **mandatory** for the ring where the scheme requires it; confirm the pilot retention/disposition behaves as specified. Confirm enforcement is **ring-only** (script #1 reports mode + scope).

1. **Scope helper** (delivered script #5, `-WhatIf` by default) to confirm/adjust the pilot ring:

```
.\ISO27001-Set-Scope.ps1 -PolicyName 'ISO27001 DLP – Data Leakage – Simulation' -RingGroup 'ISO27001 P
```

Pass/fail gate: every in-scope control has collected evidence in the register with owner/date/test status; the piloted controls are enforced **for the ring only** and behave as designed; nothing enforced outside the ring. **Rollback:** set any enforced policy back to **simulation/test** (single setting) and revert the label policy to non-mandatory — immediate, non-destructive.

Phase 5 — Expand, report, and operate (Expand → Continual improvement)

1. **Expand enforcement** from the ring to the full intended population once the pilot gate passes,

keeping documented exclusions; add the remaining in-scope Annex A controls and their assessments (`ISO27001 Assessment – Annex A – Production`).

1. **Report control coverage and score posture** (delivered script #4, read-only):

```
.\ISO27001-Report.ps1 -ControlMap .\ISO27001-ControlMap.csv -CsvPath .\ISO27001-Coverage.csv
```

It rolls up mapped-control coverage, evidence gaps (controls with no collected evidence), and the logging/monitoring evidence pull — the audit-ready coverage view.

1. **Operationalize the continual-improvement cadence (ISO Clause 10).** Schedule re-testing and re-evidencing of controls, review improvement-action owners and overdue actions, refresh the evidence register, and watch for **assessment-template / standard updates** (e.g. ISO revisions). Re-tune DLP false positives and label/retention scope as data and behavior drift.

1. **Validate end-to-end** with the delivered testing procedure (next section) and record the pass/fail evidence for the program record.

Pass/fail gate: enforcement live across the intended scope; every in-scope control mapped, configured, evidenced (owner/date/test status), and rolled up in the coverage report; the maintenance cadence is running. **Rollback:** any policy can be returned to **simulation/test** at any time as an immediate, non-destructive safety switch; individual controls can be disabled without affecting others.

Order-of-operations summary

Phase	Do	Artifact(s)	Gate	Rollback
0 Assess	Connect, baseline, confirm licensing/audit, capture score	Posture CSV	Baseline + ISO template confirmed	n/a (read-only)
1 Design	Map in-scope Annex A (from SoA) → Purview	Control map	Every applicable control mapped/owned	n/a (design)
2 Configure spine	Roles (separation), ISO assessment, action/evidence plan	Assessment, action plan, roles snapshot	Assessment + owned actions exist	Remove pilot assessment
3 Configure controls	Labels/DLP/retention in **simulation/test**; confirm audit/crypto	Label/DLP/retention pilot objects	All in sim/test, correct scope	Unpublish/delete pilot objects
4 Validate/Pilot	Collect evidence, enforce to ring	Evidence register, pilot ring	Evidence complete; ring-only enforce	Back to simulation/test
5 Expand/Operate	Broaden scope, report coverage, run cadence	Coverage report, production assessment	Full-scope enforce, coverage evidenced	Simulation/test / disable

5. Testing & Validation — Microsoft Purview ISO 27001 Compliance Program

Validate the program against explicit **pass/fail gates**. The three headline gates for this solution are: **(A) every in-scope Annex A control maps to a configured Purview control**, **(B) each mapped control**

carries collected evidence (owner, date, test status), and **(C) the high-impact controls behave as designed and were piloted in simulation/test first**. Run every functional test with **non-real, clearly-fake sample data** (e.g. the Microsoft-documented test credit-card number `4111 1111 1111 1111`) — never real customer/employee data — and record the evidence.

> *These tests prove the **technical controls work and are evidenced**. They do **not** determine certification, applicability, or adequacy — those are ISMS / risk / compliance / certification-body sign-offs, captured alongside the evidence below.*

Test A — Control mapping & coverage (nothing in-scope is unmapped)

#	Test	Steps	Pass condition
A1	Every SoA control mapped	Cross-check `ISO27001 Control Map – AnnexA-to-Purview` against the in-scope controls in the SoA.	Every applicable Annex A control is mapped to a Purview capability **or** explicitly marked out-of-Purview with a reason.
A2	Mapping is real, not asserted	For each mapped control, confirm the named Purview object exists (`ISO27001-Discovery.ps1` / `ISO27001-ControlEvidence.ps1`).	Each mapped capability resolves to an actual configured object (label, DLP policy, retention policy, audit state).
A3	Partial-evidence controls flagged	Review controls where Purview provides only partial evidence.	Partial coverage is labelled "partial" in the map — never claimed as fully met.
A4	Out-of-scope controls excluded cleanly	Confirm organizational/people/physical Annex A controls are marked out-of-Purview.	No out-of-Purview control is falsely mapped to a Purview capability.

Gate A (pass): the control map accounts for every in-scope Annex A control — mapped, partial, or out-of-Purview — with each mapped capability confirmed to exist.

Test B — Evidence collection (each control is defensible)

#	Test	Steps	Pass condition
B1	Evidence register complete	Run `ISO27001-ControlEvidence.ps1 -ControlMap ... -CsvPath ...` and review the register.	Every mapped control has a row with technical state, owner, date, and test status; **evidence gaps are listed**.

#	Test	Steps	Pass condition
B2	Audit/logging evidence present	Confirm unified audit is on and capturing label/DLP/retention activity (A.8.15/8.16).	Audit ingestion enabled; `ISO27001-Report.ps1` returns relevant activity events.
B3	Improvement-action evidence attached	In Compliance Manager, spot-check improvement actions tied to configured controls.	The action carries implementation status, test status/date, and attached evidence.
B4	Coverage roll-up	Run `ISO27001-Report.ps1 -ControlMap ... -CsvPath ...`.	The coverage report shows mapped-control coverage and flags any control with no collected evidence.

Gate B (pass): the evidence register and coverage report show every in-scope mapped control with collected evidence and no unexplained gap.

Test C — Technical control behaviour & simulate-first discipline

#	Test	Steps	Pass condition
C1	Classification/labelling works (A.5.12/5.13)	In the pilot ring, apply the label scheme to a test document; where the label applies encryption, confirm it.	Label applies and (if configured) protection/encryption is enforced on the item.
C2	Data leakage prevented (A.8.12)	With DLP enforced for the ring, attempt to send/share fake-SIT content externally.	Action is blocked/tipped per policy; a DLP event is logged. Below-threshold content is correctly **not** matched.
C3	Retention/deletion behaves (A.8.10/5.33)	Apply the pilot retention/label to test content; verify retention holds and disposition/deletion behaves as specified (disposition review where required).	Content is retained for the configured period and disposition/deletion follows the specified rule.
C4	Cryptography evidence (A.8.24/5.14)	Confirm label-applied encryption / message encryption on a test transfer.	Protected content is encrypted in transit/at rest per configuration.

#	Test	Steps	Pass condition
C5	Simulate/test first	Confirm each high-impact control (DLP, labels, retention) ran in **simulation/test/pilot** before enforcement.	Evidence shows a simulation/test stage preceded enforcement for every high-impact control.

Gate C (pass): each configured technical control behaves as designed for the pilot ring, and each was piloted in simulation/test before enforcement.

Simulate-first & rollback validation

#	Test	Pass condition
S1	Nothing enforced outside the ring	Users/devices **outside** `ISO27001 Pilot Ring – Stage1` experience no blocking/mandatory labelling during pilot.
S2	Instant rollback	Setting any enforced DLP/retention policy back to **simulation/test** (and the label policy to non-mandatory) immediately removes enforcement with no data change.
S3	Scripts are safe-by-default	`ISO27001-Config.ps1` / `ISO27001-Set-Scope.ps1` run **without** `-Commit` make no change (`-WhatIf` output only); Discovery / ControlEvidence / Report are read-only.

Evidence to capture (for the deliverable record)

- Baseline posture CSV (Phase 0), licensing confirmation, and the current Compliance Score.
- The signed-off `ISO27001 Control Map – AnnexA-to-Purview` (Gate A).
- The `ISO27001 Evidence – Register` and the coverage report, with gaps listed (Gate B).
- Screenshots/logs of the technical-control tests (C1–C4) and confirmation each was piloted in simulation/test (C5/S1/S2).
- The `ISO27001 Roles – Separation Evidence` snapshot (segregation of duties, A.5.3).

Determination boundary. *These tests prove the* ***controls are configured, working, and evidenced****. Whether the ISMS scope, the SoA, the risk treatment, and the evidence* ***satisfy ISO 27001 for certification*** *is an ISMS / risk / compliance / certification-body determination, captured alongside the evidence above.*

6. Troubleshooting — Microsoft Purview ISO 27001 Compliance Program

Symptom-first fixes for the failures you actually hit standing up an ISO 27001-aligned Purview program. Most problems are one of: the ISO template not available, a control that maps but has no evidence, a technical control not behaving, missing audit/logging evidence, or a script that seems to change nothing.

Compliance Manager / assessment

The ISO/IEC 27001 assessment template isn't available to create the assessment.

- **Licensing:** the ISO template is a **premium** template — it requires **E5 / E5 Compliance** or the

Compliance Manager Premium Assessment Add-On, and the **number** of premium assessments depends on licensing/seat count. Confirm in the **M365 admin center** and **Compliance Manager** → **Assessment templates** (Req 2.1). Run `ISO27001-Discovery.ps1` for the licensing signal, then **verify in the portal** — do not assume.

- **Role:** you need a **Compliance Manager Administrator / Assessor** role to create assessments (Req 2.3).

I can't set improvement-action status or create assessments from PowerShell.

- **Expected.** Compliance Manager has **no broad public PowerShell/Graph API** — assessments,

improvement actions, and evidence upload are **portal-only**. The delivered scripts assess readiness, roles, and the **technical evidence** behind actions; they do not replace the portal.

Automatic testing isn't updating an action's status.

- Only **eligible** improvement actions auto-test from Microsoft 365 signals; others require manual

implementation/test and uploaded evidence. Availability is **plan/action-dependent** — verify, and set those actions manually.

Control mapping

I don't know which Annex A controls to map.

- The applicable controls come from the **Statement of Applicability** (Req 2.2), produced by the

ISMS/risk function — **not** from Purview. Do not infer applicability from what Purview does; get the SoA first. Applicability is a **determination**, deferred.

A control maps to Purview but Purview only partly covers it.

- Mark it **"partial"** in `ISO27001 Control Map – AnnexA-to-Purview` and note what the residual evidence

source is (an organizational/manual control). Never claim a partially-covered control is fully met — that is the auditor's call.

An organizational / people / physical Annex A control has no Purview capability.

• Correct — those are **outside Purview** and outside this program. Mark them **out-of-Purview**; that is clean scope discipline, not a gap.

Evidence collection

`ISO27001-ControlEvidence.ps1` **reports a control as** `Collected = No`**.**

• That is an **evidence gap** to close. Common causes: the underlying object doesn't exist yet (build it in Phase 3), the account lacks the **role** to read it (labels/DLP/retention/audit — Req 2.4), or Graph isn't connected for the licensing/Conditional-Access signal (`Connect-MgGraph -Scopes Organization.Read.All, Policy.Read.All`).

The evidence register looks stale.

• It reflects the **live technical state at run time** — re-run it on the **continual-improvement cadence **(Best Practices). Attach the fresh export to the matching Compliance Manager improvement action and update** test status/date**.

Technical controls not behaving

A DLP policy matches nothing / doesn't block.

• Confirm the policy's **mode** — a **simulation** policy evaluates and logs but does **not** block (that's expected during pilot); a **disabled** policy does nothing. Check with `ISO27001-Discovery.ps1` (Mode column). To block, enforce it for the pilot ring (Implementation Phase 4).

• Check **instance count/confidence** on the rule and that the test identity/location is **in scope** and not excluded. **New/changed DLP policies take time to propagate** (up to ~1 hour, longer for some locations) — wait before concluding it's broken.

Sensitivity labels aren't appearing for users.

• Confirm the label is **published in a label policy** scoped to those users (`Get-LabelPolicy`), and allow for **publish latency**. During pilot the policy is scoped to the ring only — users outside the ring correctly see nothing.

Retention/disposition isn't behaving as specified.

• Confirm the retention policy is **enabled and scoped** to the test content, and allow for **provisioning latency**. **Remember the** retention duration/action reflects the records schedule** (a records/legal determination) — if the behaviour is "wrong," confirm it against the schedule, not against an assumption.

Audit / logging evidence

No logging/monitoring evidence (A.8.15/8.16) is being collected.

• Confirm **unified audit logging is ON** (`Get-AdminAuditLogConfig | Select UnifiedAuditLogIngestionEnabled`, or the Purview Audit page — Req 2.5). Audit data **only accrues from when it is enabled** — a late enablement is a permanent gap for the prior period.

• `ISO27001-Report.ps1` returns nothing → widen `-Days` (freshly configured controls need **dwell

time**), confirm audit logging is on, and confirm your account has the** audit/View-Only** role.

Scripts / tooling

A script seems to make no change.

• **By design.** `ISO27001-Config.ps1` and `ISO27001-Set-Scope.ps1` are `-WhatIf` **by default** — writes

require `-Commit`. Discovery / ControlEvidence / Report are **read-only**. Re-run with `-Commit` to apply an intended write.

• `ISO27001-Config.ps1` **refuses to touch a policy that is already enforcing** and **never sets enforce**

— moving a control to enforcement is a deliberate portal step after the pilot gate.

`Connect-IPPSSession` **or a cmdlet fails.**

• Ensure the **ExchangeOnlineManagement** module is installed/updated and you're using a **modern-auth /

MFA-capable **admin. A missing** role** (Compliance/DLP/Records/Audit) surfaces as "cmdlet not recognized" or access denied — assign the least-privilege role for that control area (Req 2.4).

Fast triage table

Symptom	First check
ISO template unavailable	Licensing (E5 / E5 Compliance / premium add-on) + Compliance Manager role
Can't script assessments	Expected — Compliance Manager is portal-only; scripts do evidence, not assessments
Don't know what to map	Get the **SoA** from the ISMS/risk function — applicability is deferred
Control partly covered	Mark "partial"; never claim fully met
Evidence `Collected = No`	Object missing, role missing, or Graph not connected
DLP matches nothing / no block	Mode (sim/disabled), instance count/confidence, scope, propagation time
Labels not appearing	Published in a label policy? scoped to those users? publish latency
No audit evidence	Unified audit ON? enabled late = gap; dwell time; audit role
Script changes nothing	`-WhatIf` default — pass `-Commit`; Config never enforces

Symptom	First check
Cmdlet/connect fails	Module updated, modern auth, correct least-privilege role

7. Best Practices — Microsoft Purview ISO 27001 Compliance Program

Field-tested practices for running an ISO 27001-aligned Purview program so the controls stay configured, the evidence stays current, and the audit is defensible. These complement the Implementation and Testing guides.

Let the SoA drive the map — never the other way around

• Map **only the in-scope, applicable Annex A controls from the Statement of Applicability**. Do not reverse-engineer applicability from what Purview happens to do — applicability is the ISMS/risk function's determination, and mapping controls that aren't in scope wastes effort and confuses auditors.

• Be explicit about **what Purview does *not* cover** — organizational, people, and physical controls live outside this program. Marking them out-of-Purview is itself good evidence of scope discipline.

• Where Purview provides only **partial** evidence for a control, say "partial" — an auditor trusts a program that is honest about its boundaries far more than one that claims everything is met.

Simulate/test before you enforce — always

• **Never** switch a new or materially changed **DLP, sensitivity-label, or retention** control straight to enforce. Run DLP in **simulation**, publish labels **non-mandatory** to a pilot ring, and apply retention to a **pilot scope** first — long enough to see real behaviour before expanding.

• Treat **simulation/test/non-mandatory** as your permanent safety switch: any enforced control reverts in one setting with no data change — this is your rollback.

• Roll DLP and label enforcement out **audit/tip-first**, then escalate to block/mandatory one control/category at a time, re-validating after each.

Evidence is the product — automate its collection

• ISO auditors want **evidence with an owner, a date, and proof**. Run the delivered `ISO27001-ControlEvidence.ps1` on a **recurring cadence** so the register reflects the live technical state, not a one-time snapshot.

• Attach the exported evidence to the matching **Compliance Manager improvement action** and set **test

status/date** — keep the assessment and the technical reality in lockstep.

• **Enable automatic testing** in Compliance Manager for eligible actions so technical controls

self-update from Microsoft 365 signals — fewer manual re-checks, fresher evidence. Availability is plan/action-dependent — verify.

• **Turn on unified audit logging early** (Audit Premium where longer retention is needed). Audit data

only accrues from the moment it is enabled — a late enablement is a permanent evidence gap for that period.

Segregation of duties (A.5.3) — build it into roles

• Assign **Compliance Manager Administrators / Assessors / Contributors / Readers** least-privilege, and

separate program administrators from action contributors from read-only auditors. The role separation is itself an auditable control — snapshot it (`ISO27001 Roles – Separation Evidence`).

• Do the same for the supporting controls: separate label/DLP/retention **authors** from **reviewers**

where possible, and give oversight/audit **read-only** access.

Classification, DLP, and retention hygiene

• Keep the **label taxonomy small and meaningful** (e.g. Public / Internal / Confidential / Highly

Confidential) — a sprawling scheme users can't reason about undermines A.5.12/5.13.

• **Reuse built-in SITs** for DLP where they fit; tune confidence and instance counts so the data-leakage

control (A.8.12) is low-noise — false positives erode trust in every control.

• Configure retention/disposition to the **records requirements** — but remember the **schedule and file

plan are records/legal determinations**; use** disposition review** where records must be reviewed before deletion (A.5.33 / A.8.10).

Insider Risk / Communication Compliance — privacy by design

• If you use insider-risk or communication-compliance signals as evidence for monitoring controls

(A.8.16 / A.6.8), apply **privacy-by-design**: pseudonymize where the capability supports it, restrict access with **strict role separation**, and treat case **outcomes** as **HR/legal** determinations — the program provides the technical signal, not the verdict.

Operate as a continual-improvement program (Clause 10)

• ISO 27001 is a **management system**, not a one-time build. Run a **recurring cadence**: re-test and

re-evidence controls, review overdue improvement actions and owners, refresh the coverage report, and re-tune DLP/labels/retention as data and behaviour drift.

• **Watch for standard/template updates** — Annex A and the Compliance Manager ISO template evolve;

re-map when they change.

• Keep a **change log** of every simulate→enforce transition and every control change, with the ISMS/compliance sign-off attached.

Stay inside the boundary

• **Verify licensing/tenant** before relying on any premium template, endpoint/advanced DLP, auto-labeling, or Audit Premium capability — plans and portal paths evolve; don't assume a feature is present.

• Purview provides **configured controls and evidence** — **not** the risk assessment, the SoA, the management-system clauses, or the **certification**. Those are ISMS / risk / compliance / certification-body determinations. Deliver the control and the proof; let them own the decision.

8. Deliverables Summary — Microsoft Purview ISO 27001 Compliance Program

What you receive in this solution, and what "done" looks like.

Documentation

Document	What it gives you
Solution Overview	The program model — mapping in-scope Annex A controls to Purview capabilities, the Compliance Manager assessment spine, the supporting technical controls (labels, DLP, retention, audit, encryption), and the Assess→Design→Configure→Pilot(simulate/test)→Validate→Expand journey; naming convention and the Annex A→Purview mapping table.
Requirements Guide	Solution-specific prerequisites (licensing for the ISO template + advanced controls, the SoA/risk inputs from the ISMS function, Compliance Manager role separation, roles for labels/DLP/retention/audit, unified audit enabled, classification intent, pilot ring, evidence owner) each with verify/implement steps, on top of the six category prerequisites.
Implementation Guide	The exact ordered phases: baseline → map Annex A (from SoA) → stand up the assessment spine → configure technical controls **in simulation/test** → validate evidence and enforce to a pilot ring → expand and operate; each phase named, gated, and with a rollback.
Testing & Validation	Pass/fail gates for the three headline outcomes — controls mapped (A), evidence collected (B), technical controls behave and were piloted (C) — plus simulate-first and rollback checks, all with fake test data.

Document	What it gives you
Troubleshooting Guide	The common failure modes (ISO template missing, no evidence collected, controls not behaving, audit gaps, no alerts) and how to resolve them.
Best Practices	SoA-driven mapping, simulate-first discipline, evidence automation, segregation of duties, classification/DLP/retention hygiene, privacy-by-design for insider-risk signals, and continual improvement.
Executive Summary	One-page business framing for approvers.

PowerShell tools (5) — Security & Compliance PowerShell / Graph

All tools are **read-only or `-WhatIf` by default**; writes require an explicit `-Commit` and never leave a policy in enforce. No credentials are stored in code. They connect via `Connect-IPPSSession` and/or `Connect-MgGraph`. **Compliance Manager has no broad public API** — the scripts assess readiness, roles, and the technical evidence behind controls; they do not create assessments (that is done in the portal).

#	Script	Role	Default safety
1	**ISO27001-Discovery.ps1**	Posture + control-coverage assessment: unified-audit state, existing DLP/label/retention objects and their mode, and licensing signals that gate the ISO template and advanced controls.	Read-only
2	**ISO27001-Config.ps1**	Supporting-control configuration helper: creates/updates a DLP/retention control **in simulation/test mode** and reports the intended change.	`-WhatIf` (writes need `-Commit`; never leaves a policy in enforce)
3	**ISO27001-ControlEvidence.ps1**	Evidence collector: for each mapped Annex A control, confirms the technical state (audit, DLP+mode, labels, retention, licensing/CA signals) and builds the evidence register.	Read-only

#	Script	Role	Default safety
4	**ISO27001-Report.ps1**	Control-coverage + evidence-gap report and logging/monitoring evidence pull from the unified audit log.	Read-only
5	**ISO27001-Set-Scope.ps1**	Scope helper: reports and (with `-Commit`) adjusts a policy's included/excluded users/groups (e.g. the pilot ring).	`-WhatIf` (writes need `-Commit`)

Definition of done

• Every **in-scope, applicable Annex A control** (from the SoA) mapped to a Purview capability — or marked

out-of-Purview — in `ISO27001 Control Map – AnnexA-to-Purview`, signed off by the ISMS function.

• The **ISO/IEC 27001 assessment** stood up in Compliance Manager with an owned, dated improvement-action

/ evidence plan and role separation snapshotted.

• The supporting technical controls (**labels, DLP, retention/disposition**) configured and **proven in

simulation/test**, then enforced to the pilot ring;** unified audit **and** encryption** evidence confirmed.

• The **evidence register** and **coverage report** complete — every mapped control with owner, date, test

status, and no unexplained gap.

• Simulate-first, ring-only enforcement, and safe-by-default scripts verified; change log and ISMS/

compliance sign-offs captured; the continual-improvement cadence running.

> ***Boundary:*** *the solution delivers the* ***configured technical controls and the audit-ready evidence****. The* ***ISMS scope, the risk assessment and treatment, the Statement of Applicability (which Annex A controls apply), the management-system clauses (4–10), retention schedules / records file plans, and the certification determination*** *are ISMS / risk / compliance / records / legal / certification-body determinations, captured alongside the delivered evidence.*

Appendix A — PowerShell Scripts

Included in the accompanying ZIP. Each script's header documents full usage.

ISO27001-Config.ps1

Purpose: Creates or updates a supporting technical control that backs an ISO 27001 Annex A control — a DLP policy (A.8.12 data leakage) or a retention policy (A.8.10 information deletion / A.5.33 records) — and always in a SAFE, NON-ENFORCING mode: DLP is created/left in simulation (TestWithoutNotifications), retention is created/left in test mode where supported. Read-only by default (prints the intended change under -WhatIf); a write requires the explicit -Commit switch. The script NEVER sets a policy to enforce (Mode=Enable) — moving to enforcement is a deliberate portal action after the pilot passes. HOW TO RUN Preview (default, no change): powershell -ExecutionPolicy Bypass -File .\ISO27001-Config.ps1 -Control DLP -PolicyName 'ISO27001 DLP - Data Leakage - Simulation' -WhatIf Apply the simulation-mode policy (explicit write): powershell -ExecutionPolicy Bypass -File .\ISO27001-Config.ps1 -Control DLP -PolicyName 'ISO27001 DLP - Data Leakage - Simulation' -Commit Requires Security & Compliance PowerShell (Connect-IPPSSession). EXPECTED RESULTS Under -WhatIf: the intended create/update and the mode it would set (always simulation/test). Under -Commit: the policy exists in simulation/test mode. PASS signal: Get-DlpCompliancePolicy / Get-RetentionCompliancePolicy shows the policy in a Test*/disabled mode, never Enable. .NOTES Purview — ISO 27001 Compliance Program. Safe-by-default; -Commit required to write; never enforces. > [CmdletBinding(SupportsShouldProcess = $true)] param([Parameter(Mandatory = $true)][ValidateSet('DLP','Retention')][string]$Control, [Parameter(Mandatory = $true)][string]$PolicyName, [switch]$Commit, [switch]$WhatIf, [string]$UserPrincipalName)

How to run: Preview (default, no change): powershell -ExecutionPolicy Bypass -File .\ISO27001-Config.ps1 -Control DLP -PolicyName 'ISO27001 DLP - Data Leakage - Simulation' -WhatIf Apply the simulation-mode policy (explicit write): powershell -ExecutionPolicy Bypass -File .\ISO27001-Config.ps1 -Control DLP -PolicyName 'ISO27001 DLP - Data Leakage - Simulation' -Commit Requires Security & Compliance PowerShell (Connect-IPPSSession). EXPECTED RESULTS Under -WhatIf: the intended create/update and the mode it would set (always simulation/test). Under -Commit: the policy exists in simulation/test mode. PASS signal: Get-DlpCompliancePolicy / Get-RetentionCompliancePolicy shows the policy in a Test*/disabled mode, never Enable. .NOTES Purview — ISO 27001 Compliance Program. Safe-by-default; -Commit required to write; never enforces. > [CmdletBinding(SupportsShouldProcess = $true)] param([Parameter(Mandatory = $true)][ValidateSet('DLP','Retention')][string]$Control, [Parameter(Mandatory = $true)][string]$PolicyName, [switch]$Commit, [switch]$WhatIf, [string]$UserPrincipalName)

ISO27001-ControlEvidence.ps1

Purpose: For each mapped ISO 27001 Annex A control, confirms the underlying Purview technical state and writes an evidence-register row (control, capability, state, owner, date). It checks: unified audit logging (A.8.15/8.16), sensitivity labels + label policies (A.5.12/5.13), DLP policies and their mode (A.8.12), retention policies (A.8.10/5.33), and — via Microsoft Graph — the licensing signal and Conditional Access policy count (access-control evidence). Read-only — queries only. Optionally reads a control-map CSV (Control,Capability,Owner) to align rows to your SoA mapping. HOW TO RUN powershell -ExecutionPolicy Bypass -File .\ISO27001-ControlEvidence.ps1 -ControlMap .\ISO27001-ControlMap.csv -CsvPath .\ISO27001-Evidence.csv Requires Security & Compliance PowerShell (Connect-IPPSSession); optional

Connect-MgGraph for licensing / Conditional Access signals (-Scopes Organization.Read.All, Policy.Read.All). EXPECTED RESULTS A console evidence table and a CSV register with, per control, the confirmed technical state and a Collected (Yes/No) flag. PASS gate: every mapped control has Collected=Yes; controls with Collected=No are the evidence gaps to close. Nothing is changed. .NOTES Purview — ISO 27001 Compliance Program. Read-only evidence collection. No changes made. > [CmdletBinding()] param([string]$ControlMap, [string]$CsvPath, [string]$UserPrincipalName)

How to run: powershell -ExecutionPolicy Bypass -File .\ISO27001-ControlEvidence.ps1 -ControlMap .\ISO27001-ControlMap.csv -CsvPath .\ISO27001-Evidence.csv Requires Security & Compliance PowerShell (Connect-IPPSSession); optional Connect-MgGraph for licensing / Conditional Access signals (-Scopes Organization.Read.All, Policy.Read.All). EXPECTED RESULTS A console evidence table and a CSV register with, per control, the confirmed technical state and a Collected (Yes/No) flag. PASS gate: every mapped control has Collected=Yes; controls with Collected=No are the evidence gaps to close. Nothing is changed. .NOTES Purview — ISO 27001 Compliance Program. Read-only evidence collection. No changes made. > [CmdletBinding()] param([string]$ControlMap, [string]$CsvPath, [string]$UserPrincipalName)

ISO27001-Discovery.ps1

Purpose: Builds the baseline for an ISO 27001-aligned Purview program: whether unified audit logging is ON (the logging/monitoring evidence backbone for A.8.15/A.8.16), the existing sensitivity labels, DLP policies and their MODE (enforce vs simulation/test vs disabled), and retention policies present in the tenant, plus licensing signals (via Graph) that gate the ISO Compliance Manager template and advanced controls. Read-only — makes no changes. HOW TO RUN powershell -ExecutionPolicy Bypass -File .\ISO27001-Discovery.ps1 -CsvPath .\ISO27001-Posture.csv Requires Security & Compliance PowerShell (Connect-IPPSSession via ExchangeOnlineManagement); optional Microsoft Graph (Connect-MgGraph) for the licensing signal. EXPECTED RESULTS A console summary of audit state, labels, DLP policies (Name/Mode), and retention policies, plus an optional CSV inventory. PASS signal: unified audit is enabled; high-impact policies you expect to be piloting report a simulation/test/disabled mode; anything already enforcing that you did not intend is flagged for review. Note: Compliance Manager assessments are portal-only and are not enumerated here. .NOTES Purview — ISO 27001 Compliance Program. Read-only baseline. No changes made. > [CmdletBinding()] param([string]$CsvPath, [string]$UserPrincipalName)

How to run: powershell -ExecutionPolicy Bypass -File .\ISO27001-Discovery.ps1 -CsvPath .\ISO27001-Posture.csv Requires Security & Compliance PowerShell (Connect-IPPSSession via ExchangeOnlineManagement); optional Microsoft Graph (Connect-MgGraph) for the licensing signal. EXPECTED RESULTS A console summary of audit state, labels, DLP policies (Name/Mode), and retention policies, plus an optional CSV inventory. PASS signal: unified audit is enabled; high-impact policies you expect to be piloting report a simulation/test/disabled mode; anything already enforcing that you did not intend is flagged for review. Note: Compliance Manager assessments are portal-only and are not enumerated here. .NOTES Purview — ISO 27001 Compliance Program. Read-only baseline. No changes made. > [CmdletBinding()] param([string]$CsvPath, [string]$UserPrincipalName)

ISO27001-Report.ps1

Purpose: Produces the audit-ready coverage view for the ISO 27001 Purview program: rolls up mapped-control coverage from a control-map CSV (Control,Capability,Owner,Collected) if provided, and pulls logging/monitoring evidence (A.8.15/8.16) from the unified audit log for the DLP/label/retention record

types over a time window. Read-only — queries Search-UnifiedAuditLog only; makes no changes. HOW TO RUN powershell -ExecutionPolicy Bypass -File .\ISO27001-Report.ps1 -ControlMap .\ISO27001-ControlMap.csv -Days 30 -CsvPath .\ISO27001-Coverage.csv Requires Security & Compliance PowerShell (Connect-IPPSSession) and audit logging enabled. EXPECTED RESULTS A console coverage summary (controls mapped / evidenced / gaps) and a breakdown of compliance activity events by record type, plus an optional CSV. PASS gate: coverage report shows every in-scope control mapped and evidenced with no unexplained gap, and audit activity is present for the configured controls. .NOTES Purview — ISO 27001 Compliance Program. Read-only reporting from control map + unified audit log. > [CmdletBinding()] param([string]$ControlMap, [int]$Days = 30, [string]$CsvPath, [string]$UserPrincipalName)

How to run: powershell -ExecutionPolicy Bypass -File .\ISO27001-Report.ps1 -ControlMap .\ISO27001-ControlMap.csv -Days 30 -CsvPath .\ISO27001-Coverage.csv Requires Security & Compliance PowerShell (Connect-IPPSSession) and audit logging enabled. EXPECTED RESULTS A console coverage summary (controls mapped / evidenced / gaps) and a breakdown of compliance activity events by record type, plus an optional CSV. PASS gate: coverage report shows every in-scope control mapped and evidenced with no unexplained gap, and audit activity is present for the configured controls. .NOTES Purview — ISO 27001 Compliance Program. Read-only reporting from control map + unified audit log. > [CmdletBinding()] param([string]$ControlMap, [int]$Days = 30, [string]$CsvPath, [string]$UserPrincipalName)

ISO27001-Set-Scope.ps1

Purpose: Reports a DLP policy's current included/excluded locations and, with the explicit -Commit switch, narrows a policy to the pilot ring (an included distribution group / mail-enabled security group) so enforcement is limited to Stage-1 pilot users before broad rollout. Read-only by default (-WhatIf prints the intended change). The script only NARROWS scope to the named ring; it never broadens scope tenant-wide and never changes a policy's enforcement mode. HOW TO RUN Preview current scope (default, no change): powershell -ExecutionPolicy Bypass -File .\ISO27001-Set-Scope.ps1 -PolicyName 'ISO27001 DLP - Data Leakage - Simulation' -WhatIf Restrict to the pilot ring (explicit write): powershell -ExecutionPolicy Bypass -File .\ISO27001-Set-Scope.ps1 -PolicyName 'ISO27001 DLP - Data Leakage - Simulation' -RingGroup 'ISO27001 Pilot Ring - Stage1' -Commit Requires Security & Compliance PowerShell (Connect-IPPSSession). EXPECTED RESULTS Under -WhatIf: the current scope and the intended pilot-ring restriction. Under -Commit: the policy's Exchange/SharePoint/OneDrive locations are scoped to the ring group. PASS signal: Get-DlpCompliancePolicy shows the *DistributionGroup / *AccountScope set to the ring only. .NOTES Purview — ISO 27001 Compliance Program. Safe-by-default; -Commit required to write; only narrows scope. > [CmdletBinding(SupportsShouldProcess = $true)] param([Parameter(Mandatory = $true)][string]$PolicyName, [string]$RingGroup, [switch]$Commit, [switch]$WhatIf, [string]$UserPrincipalName)

How to run: Preview current scope (default, no change): powershell -ExecutionPolicy Bypass -File .\ISO27001-Set-Scope.ps1 -PolicyName 'ISO27001 DLP - Data Leakage - Simulation' -WhatIf Restrict to the pilot ring (explicit write): powershell -ExecutionPolicy Bypass -File .\ISO27001-Set-Scope.ps1 -PolicyName 'ISO27001 DLP - Data Leakage - Simulation' -RingGroup 'ISO27001 Pilot Ring - Stage1' -Commit Requires Security & Compliance PowerShell (Connect-IPPSSession). EXPECTED RESULTS Under -WhatIf: the current scope and the intended pilot-ring restriction. Under -Commit: the policy's Exchange/SharePoint/OneDrive locations are scoped to the ring group. PASS signal: Get-DlpCompliancePolicy shows the *DistributionGroup / *AccountScope set to the ring only. .NOTES Purview — ISO 27001 Compliance Program. Safe-by-default; -Commit required to write; only narrows

scope. > [CmdletBinding(SupportsShouldProcess = $true)] param([Parameter(Mandatory = $true)][string]$PolicyName, [string]$RingGroup, [switch]$Commit, [switch]$WhatIf, [string]$UserPrincipalName)